

# Team-9 Project 1

Marshall Nelson, Jewels Wolter, Kate Moreland, Spencer Shirah

February 6th 2026

## 1 Executive Summary

Team 9 performed a Red Team vulnerability assessment from 1/30/26 to 2/6/26. We employed tactics that imitate real-world threats to target the Vulnerable VM we were provided. Our Activities include Reconnaissance, Enumeration, Exploit, and Data Exfiltration in order to achieve the following goals.

- Identification of System Vulnerabilities
- Identification of Insecure Practices
- Identify Areas of Improvement

Although this report will primarily focus on negative observations and areas of improvement, we wanted to provide a list of positive observations.

- We were not able to trivially gain root access.
- They maintain the principle of least privilege and only grant temporary administrator access.

Throughout our red team engagement, we were able to identify key areas that require improvement and further consideration. Our findings are explained in Detail in the "Observations and Recommendations" Section, a summary of our Observations is provided here:

- Anonymous FTP is allowed
- Incorrect Filesystem Permissions
- Inadequate Password Policies
- Exposure of Sensitive and Internal Files
- Credential Reuse
- Inadequate Privilege Escalation Policies

We were able to achieve all of our goals and propose recommendations that cover software vulnerabilities and misconfigurations, preventative policies, and overall security mindset of the target company. We are hopeful that we can help the target company to adopt a more security aware mindset for the protection of the company, employees, and customers.

Team 9 has provided specific recommendations for reducing the risks imposed by these issues in the "Observations and Recommendations" section of this report. We appreciate the opportunity to practice and develop our knowledge in a scenario that loosely imitates the real-world. We look forward to our future projects.

## 2 Table of Contents

### Contents

|   |                   |   |
|---|-------------------|---|
| 1 | Executive Summary | 1 |
|---|-------------------|---|

|          |                                                                                       |           |
|----------|---------------------------------------------------------------------------------------|-----------|
| <b>2</b> | <b>Table of Contents</b>                                                              | <b>1</b>  |
| <b>3</b> | <b>Methodology and Goals</b>                                                          | <b>2</b>  |
| <b>4</b> | <b>Scenario and Scope</b>                                                             | <b>2</b>  |
| 4.1      | Scenario . . . . .                                                                    | 2         |
| 4.2      | Scope . . . . .                                                                       | 3         |
| <b>5</b> | <b>Attack Narrative</b>                                                               | <b>3</b>  |
| 5.1      | Reconnaissance . . . . .                                                              | 3         |
| 5.2      | FTP Server . . . . .                                                                  | 4         |
| 5.2.1    | Anonymous Authentication . . . . .                                                    | 4         |
| 5.2.2    | Alice User Directory Access . . . . .                                                 | 5         |
| 5.2.3    | Bob User Directory Access . . . . .                                                   | 6         |
| 5.3      | SSH Server . . . . .                                                                  | 7         |
| 5.3.1    | Credential Pivot from FTP and HTTP . . . . .                                          | 7         |
| 5.3.2    | SSH Authentication Attempts . . . . .                                                 | 7         |
| 5.3.3    | Successful SSH Access as Alice . . . . .                                              | 7         |
| 5.3.4    | Additional User Access Attempts (Bob) . . . . .                                       | 9         |
| 5.4      | Apache Web Server . . . . .                                                           | 10        |
| 5.4.1    | Directory Brute-Force with Dirb . . . . .                                             | 10        |
| 5.4.2    | Sensitive Data Exposure . . . . .                                                     | 11        |
| <b>6</b> | <b>Observations and Recommendations</b>                                               | <b>14</b> |
| 6.0.1    | Observation 1: Insecure FTP Configuration and Anonymous Access . . . . .              | 14        |
| 6.0.2    | Observation 2: Inadequate File System Permissions Management . . . . .                | 14        |
| 6.0.3    | Observation 3: Inadequate Password Policies . . . . .                                 | 14        |
| 6.0.4    | Observation 4: Exposure of Sensitive Backup and Internal Files via Web Server . . . . | 14        |
| 6.0.5    | Observation 5: Credential Reuse Across Services . . . . .                             | 15        |
| 6.0.6    | Observation 6: Improper Management of Temporary Privileged Access . . . . .           | 15        |
| <b>7</b> | <b>Conclusion</b>                                                                     | <b>15</b> |

## 3 Methodology and Goals

Red Team Engagements performed by Team 9 are purely academic in nature. We attempt to learn and practice skills and techniques used in the real world. Especially those mirrored in the Mitre ATT&CK Framework. The primary interest of this engagement are reconnaissance, initial access, and data exfiltration. We aim to use the limited knowledge we have to determine misconfigured services, insecure practices, and other vulnerabilities to mitigate the current risks our customer faces. Our primary goals include:

- Identify Service Misconfigurations
- Gather Information
- Identify Poor Security Practices

## 4 Scenario and Scope

### 4.1 Scenario

We were provided with a vulnerable virtual machine and tasked with performing a vulnerability assessment. This is a "Black-Box" Scenario where we have no information about the machine or its service, other than the fact that it is running Ubuntu. Our goal is to identify, exploit, and record every vulnerability that we find.

## 4.2 Scope

As a single assignment our scope is restricted to a reasonable Time to Exploit (TTE) on the vulnerabilities we find. For Example Misconfigured services, permissions, and applications are heavily prioritized over kernel bugs.

## 5 Attack Narrative

### 5.1 Reconnaissance

To begin our analysis of the vulnerable VM, we first had to identify and locate the vm on our network. We used NMAP to scan the subnet to locate the available hosts. Figure 1 shows the results from running the command "nmap -sn 192.168.56.0/24". Since we know that our client ip is 192.168.50, so we ran the command "nmap -sV 192.168.56.21 192.168.56.100" to identify the target and it's services. Our service scan, Figure 2, shows that the target has three services running: FTP on port 21, SSH on port 22, and an Apache WebServer on port 80. This signifies three potential attack surfaces for various exploits.

```
Nmap scan report for 192.168.56.1
Host is up (0.0060s latency).
MAC Address: 0A:00:27:00:00:0D (Unknown)
Nmap scan report for 192.168.56.21
Host is up (0.0045s latency).
MAC Address: 08:00:27:6E:6F:3F (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)
Nmap scan report for 192.168.56.100
Host is up (0.0052s latency).
MAC Address: 08:00:27:EE:21:19 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)
Nmap scan report for 192.168.56.50
Host is up.
Nmap done: 128 IP addresses (4 hosts up) scanned in 2.30 seconds
```

Figure 1: Initial nmap Scan Results

```
(kali@kali)-[~]
$ nmap -sV 192.168.56.21 192.168.56.100
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-31 13:31 EST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.21
Host is up (0.0045s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protoco
l 2.0)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
MAC Address: 08:00:27:6E:6F:3F (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.56.100
Host is up (0.0042s latency).
All 1000 scanned ports on 192.168.56.100 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 08:00:27:EE:21:19 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 2 IP addresses (2 hosts up) scanned in 8.07 seconds
```

Figure 2: nmap service scan

## 5.2 FTP Server

The first service we attempted to exploit was the FTP Server. An FTP Server is a promising find, there are some common misconfigurations that we can exploit, which allow us direct access to the target file system. The most common attack chain for FTP is Authentication -> Directory Traversal -> Data Exfiltration.

### 5.2.1 Anonymous Authentication

Upon connection to the FTP server it prompts for a username and password. We began by attempting a variety of common usernames, admin:admin, admin:password, user:password, root:password. None of these were successful, however, when we enter the username "anonymous", we are granted access without a password. Script 1, shows the anonymous authentication and directory listing within the ftp server.

Listing 1: Anonymous FTP: FTP Access Withou Authentication

```
1 Script started on 2026-01-31 14:22:44-05:00 [TERM="xterm-256color" TTY="/dev/pts/0" COLUMNS="125" LINES="36"]
2
3 kali@kali: ~/temp
4 ftp 192.168.56.21
5
6 Connected to 192.168.56.21.
7 220 (vsFTPD 3.0.5)
8 Name (192.168.56.21:kali): anonymous
9 230 Login successful.
10 Remote system type is UNIX.
11 Using binary mode to transfer files.
12 ftp> ls
13 229 Entering Extended Passive Mode (|||37349|)
14 150 Here comes the directory listing.
15 drwxr-xr-x  5 1005  100          4096 Jan 30 14:18 alice
16 drwxr-xr-x  5 1005  100          4096 Jan 30 14:18 bob
17 drwxr-xr-x  5 1005  100          4096 Jan 30 14:18 eve
18 drwxr-xr-x  5 1005  100          4096 Jan 30 14:18 mallory
19 226 Directory send OK.
20 ftp> cd mallory
21 250 Directory successfully changed.
22 ftp> ls
23 229 Entering Extended Passive Mode (|||65026|)
24 150 Here comes the directory listing.
25 drwxr-xr-x  2 1005  100          4096 Jan 30 14:18 notes
26 drwxr-xr-x  2 1005  100          4096 Jan 30 14:18 public
27 drwxr-xr-x  2 1004  100          4096 Jan 30 14:18 uploads
28 226 Directory send OK.
29 ftp> cd notes
30 250 Directory successfully changed.
31 ftp> ls
32 229 Entering Extended Passive Mode (|||32357|)
33 150 Here comes the directory listing.
34 -rw-r--r--  1 1005  100          56 Jan 30 14:18 note_1.txt
35 -rw-r--r--  1 1005  100          56 Jan 30 14:18 note_2.txt
36 -rw-r--r--  1 1005  100          56 Jan 30 14:18 note_3.txt
37 -rw-r--r--  1 1005  100          207 Jan 30 16:04 note_4.txt
38 226 Directory send OK.
39 ftp> get note_4.txt
40 local: note_4.txt remote: note_4.txt
41 229 Entering Extended Passive Mode (|||15173|)
42 150 Opening BINARY mode data connection for note_4.txt (207 bytes).
43
44  0% |                                     |      0      0.00 KiB/s  --:-- ETA
45 100% |*****|                          |    207    0.20 KiB/s  --:-- ETA
46 226 Transfer complete.
47 207 bytes received in 00:00 (0.20 KiB/s)
48 ftp> cd
49 ftp> exit
50 221 Goodbye.
51
52
53 kali@kali: ~/temp
54 cat *.txt
55 [
56 === INTERNAL IT NOTE ===
57 User: alice
58 Temp password reset during migration
59
60 username: alice
61 password: nicole
62
63 Reminder:
64 User was supposed to change this after first login.
65 Follow up if access issues persist.
66 ]
67 Script done on 2026-01-31 14:25:09-05:00 [COMMAND_EXIT_CODE="0"]
```

Using the anonymous user, we are able to view a number of directories. Each user has a directory, with three subdirectories, notes, public, and uploads. Most of the notes are of little relevance, and we cannot access the uploads folders. However, the notes directory for the user "mallory" contains a username, alice, and the corresponding password, nicole. Figure ??, shows that note\_4.txt is larger than the other note files, and that it contains the username and password combination for the user "alice".

## 5.2.2 Alice User Directory Access

Now that we have an authorized user and password combination, we are able to use ftp and authenticate ourselves as "alice", Listing 2. The new authentication allows us to view and download files that were not initially visible to us. I would highly recommend enforcing proper user based authentication for which users have access to which files. Once again, most of the files are of no interest, however, one file contains more valuable information. The directory "/home/mallory/audit" contained a file called "alice\_review.txt". This text document explains that alice may have temporary sudo permissions. This is extremely helpful as we continue on to exploit ssh.

Listing 2: Alice FTP:

```
1 Script started on 2026-01-31 14:25:23-05:00 [TERM="xterm-256color" TTY="/dev/pts/0" COLUMNS="125" LINES="36"]
2 kali@kali: ~/temp
3
4 ftp 192.168.56.21
5 Connected to 192.168.56.21.
6 220 (vsFTPd 3.0.5)
7 Name (192.168.56.21:kali): alice
8 331 Please specify the password.
9 Password:
10 230 Login successful.
11 Remote system type is UNIX.
12 Using binary mode to transfer files.
13 ftp> ls
14 229 Entering Extended Passive Mode (|||64176|)
15 150 Here comes the directory listing.
16 drwxr-xr-x  2 1001  100      4096 Jan 30 14:18 Documents
17 drwxr-xr-x  2 1001  100      4096 Jan 30 14:18 Downloads
18 226 Directory send OK.
19 ftp> cd Documents
20 250 Directory successfully changed.
21 ftp> ls
22 229 Entering Extended Passive Mode (|||56539|)
23 150 Here comes the directory listing.
24 -rw-r-----  1 1001  100      84 Jan 30 14:18 doc_1.txt
25 -rw-r-----  1 1001  100      84 Jan 30 14:18 doc_2.txt
26 -rw-r-----  1 1001  100      84 Jan 30 14:18 doc_3.txt
27 -rw-r-----  1 1001  100      84 Jan 30 14:18 doc_4.txt
28 -rw-r-----  1 1001  100      84 Jan 30 14:18 doc_5.txt
29 -rw-r-----  1 1001  100      84 Jan 30 14:18 doc_6.txt
30 226 Directory send OK.
31 ftp> mget *
32 mget doc_1.txt [anpqy]? y
33 229 Entering Extended Passive Mode (|||30876|)
34 150 Opening BINARY mode data connection for doc_1.txt (84 bytes).
35
36  0% |
37 100% |*****| 0 0.00 KiB/s --:-- ETA
38 226 Transfer complete.
39 84 bytes received in 00:00 (0.08 KiB/s)
40 mget doc_2.txt [anpqy]? y
41 229 Entering Extended Passive Mode (|||23594|)
42 150 Opening BINARY mode data connection for doc_2.txt (84 bytes).
43
44  0% |
45 100% |*****| 0 0.00 KiB/s --:-- ETA
46 226 Transfer complete.
47 84 bytes received in 00:00 (0.08 KiB/s)
48 mget doc_3.txt [anpqy]? y
49 229 Entering Extended Passive Mode (|||34717|)
50 150 Opening BINARY mode data connection for doc_3.txt (84 bytes).
51
52  0% |
53 100% |*****| 0 0.00 KiB/s --:-- ETA
54 226 Transfer complete.
55 84 bytes received in 00:00 (0.08 KiB/s)
56 mget doc_4.txt [anpqy]? y
57 229 Entering Extended Passive Mode (|||41281|)
58 150 Opening BINARY mode data connection for doc_4.txt (84 bytes).
59
60  0% |
61 100% |*****| 0 0.00 KiB/s --:-- ETA
62 226 Transfer complete.
63 84 bytes received in 00:00 (0.08 KiB/s)
64 mget doc_5.txt [anpqy]? y
65 229 Entering Extended Passive Mode (|||26272|)
66 150 Opening BINARY mode data connection for doc_5.txt (84 bytes).
67
68  0% |
69 100% |*****| 0 0.00 KiB/s --:-- ETA
70 226 Transfer complete.
71 84 bytes received in 00:00 (6.83 KiB/s)
72 mget doc_6.txt [anpqy]? y
73 229 Entering Extended Passive Mode (|||43352|)
74 150 Opening BINARY mode data connection for doc_6.txt (84 bytes).
75
76  0% |
77 100% |*****| 0 0.00 KiB/s --:-- ETA
78 226 Transfer complete.
79 84 bytes received in 00:00 (0.08 KiB/s)
80 ftp> ls
81 229 Entering Extended Passive Mode (|||51450|)
82 150 Here comes the directory listing.
83 -rw-r-----  1 1001  100      84 Jan 30 14:18 doc_1.txt
84 -rw-r-----  1 1001  100      84 Jan 30 14:18 doc_2.txt
85 -rw-r-----  1 1001  100      84 Jan 30 14:18 doc_3.txt
86 -rw-r-----  1 1001  100      84 Jan 30 14:18 doc_4.txt
87 -rw-r-----  1 1001  100      84 Jan 30 14:18 doc_5.txt
```

```

88 -rw-r----- 1 1001 100 84 Jan 30 14:18 doc_6.txt
89 226 Directory send OK.
90 ftp> cd ..
91 250 Directory successfully changed.
92 ftp> cd Downloads
93 250 Directory successfully changed.
94 ftp> ls
95 229 Entering Extended Passive Mode (|||16615|)
96 150 Here comes the directory listing.
97 -rw-r--r-- 1 1001 100 48 Jan 30 14:18 readme.txt
98 226 Directory send OK.
99 ftp> get readme.txt
100 local: readme.txt remote: readme.txt
101 229 Entering Extended Passive Mode (|||19913|)
102 150 Opening BINARY mode data connection for readme.txt (48 bytes).
103
104 0% |
105 100% |*****| 0 0.00 KiB/s --:-- ETA
106 226 Transfer complete. 48 11.71 KiB/s 00:00 ETA
107 48 bytes received in 00:00 (11.71 KiB/s)
108 ftp> cd ..
109 250 Directory successfully changed.
110 ftp> ls
111 229 Entering Extended Passive Mode (|||24491|)
112 150 Here comes the directory listing.
113 drwxr-xr-x 2 1001 100 4096 Jan 30 14:18 Documents
114 drwxr-xr-x 2 1001 100 4096 Jan 30 14:18 Downloads
115 226 Directory send OK.
116 ftp> cd ..
117 250 Directory successfully changed.
118 ftp> ls
119 229 Entering Extended Passive Mode (|||11428|)
120 150 Here comes the directory listing.
121 drwxr-x--- 7 1001 100 4096 Jan 30 19:14 alice
122 drwxr-x--- 9 1002 100 4096 Jan 30 19:03 bob
123 drwxr-x--- 6 1003 100 4096 Jan 30 14:18 eve
124 drwxr-xr-x 7 1005 100 4096 Jan 30 19:13 ftpuser
125 drwxr-x--- 8 1004 100 4096 Jan 30 17:31 mallory
126 drwxr-x--- 4 1000 1000 4096 Jan 30 19:14 project1
127 226 Directory send OK.
128 ftp> cd bob
129 250 Directory successfully changed.
130 ftp> ls
131 229 Entering Extended Passive Mode (|||62680|)
132 150 Here comes the directory listing.
133 drwxr-xr-x 2 1002 100 4096 Jan 30 14:18 Documents
134 drwxr-xr-x 2 1002 100 4096 Jan 30 14:18 Downloads
135 drwxr-xr-x 2 1002 100 4096 Jan 30 17:31 notes
136 226 Directory send OK.
137 ftp> cd Documents
138 ftp> exit
139 221 Goodbye.
140
141
142
143 kali@kali: ~/temp/alice
144 cat *.txt
145 Owner: alice
146 Created: 2026-01-30T14:18:18Z
147 Notes: meeting notes / reminders / TODOs
148 Owner: alice
149 Created: 2026-01-30T14:18:18Z
150 Notes: meeting notes / reminders / TODOs
151 Owner: alice
152 Created: 2026-01-30T14:18:18Z
153 Notes: meeting notes / reminders / TODOs
154 Owner: alice
155 Created: 2026-01-30T14:18:18Z
156 Notes: meeting notes / reminders / TODOs
157 Owner: alice
158 Created: 2026-01-30T14:18:18Z
159 Notes: meeting notes / reminders / TODOs
160 Owner: alice
161 Created: 2026-01-30T14:18:18Z
162 Notes: meeting notes / reminders / TODOs
163 === INTERNAL IT NOTE ===
164 User: alice
165 Temp password reset during migration
166
167 username: alice
168 password: nicole
169
170 Reminder:
171 User was supposed to change this after first login.
172 Follow up if access issues persist.
173 Welcome alice.
174 If something breaks, contact IT.
175
176 Script done on 2026-01-31 14:27:40-05:00 [COMMAND_EXIT_CODE="0"]

```

### 5.2.3 Bob User Directory Access

From the Apache Web Server, we have discovered the password for bob is charlie from the users.bak file, which is the same password across all of his accounts. This authentication allows us to view and download files that were not shown before. Most of the files are not crucial, but there is one that contains important information. The todo.txt file that is in the notes directory shows that Alice will need sudo access. We may be able to use this sudo access to for more exploits in SSH.

### Listing 3: FTP Session and todo.txt Retrieval

```
1 Script started on 2026-02-01 13:23:29-06:00 [TERM="xterm-256color" TTY="/dev/pts/1" COLUMNS="77" LINES="28"]
2
3 student@kali:
4 ftp 192.168.56.21
5 Connected to 192.168.56.21.
6 220 (vsFTPd 3.0.5)
7 Name (192.168.56.21:student): bob
8 331 Please specify the password.
9 Password:
10 230 Login successful.
11 Remote system type is UNIX.
12 Using binary mode to transfer files.
13 ftp> ls
14 229 Entering Extended Passive Mode (|||30929|)
15 150 Here comes the directory listing.
16 drwxr-xr-x  2 1002    100          4096 Feb 01 16:32 Documents
17 drwxr-xr-x  2 1002    100          4096 Feb 01 16:31 Downloads
18 drwxr-xr-x  2 1002    100          4096 Feb 01 16:33 notes
19 226 Directory send OK.
20 ftp> cd notes
21 250 Directory successfully changed.
22 ftp> ls
23 229 Entering Extended Passive Mode (|||64948|)
24 150 Here comes the directory listing.
25 -rw-r--r--  1 1002    100           99 Jan 30 20:55 todo.txt
26 226 Directory send OK.
27 ftp> mget todo.txt
28 mget todo.txt [anpqy]?
29 229 Entering Extended Passive Mode (|||64276|)
30 150 Opening BINARY mode data connection for todo.txt (99 bytes).
31
32  0% |          | 0          0.00 KiB/s  --:-- ETA
33 100% |*****| 99          1.92 MiB/s  00:00 ETA
34 226 Transfer complete.
35 99 bytes received in 00:00 (155.18 KiB/s)
36 ftp> exit
37 221 Goodbye.
38
39
40 student@kali
41 cat todo.txt
42
43 TODO:
44 - Ask Mallory to review Alices access
45 - Mallory said Alice needed sudo briefly for audits
46
47 Script done on 2026-02-01 13:24:14-06:00 [COMMAND_EXIT_CODE="0"]
```

## 5.3 SSH Server

### 5.3.1 Credential Pivot from FTP and HTTP

Based on information gathered during FTP and HTTP enumeration, multiple valid username and password combinations were identified. Since SSH was exposed on port 22 and appeared to be a primary access method for system administration, these credentials were tested against the SSH service to determine whether cross-service authentication was possible.

### 5.3.2 SSH Authentication Attempts

Authentication attempts were conducted against the SSH service using credentials associated with the users alice, bob, and mallory. These users were selected based on their exposure in FTP directories and internal documentation obtained via the web server. These credentials and details are:

- alice : nicole (from FTP notes)
- bob : charlie (from users.bak and staff.txt)
- mallory (identified as system administrator)

### 5.3.3 Successful SSH Access as Alice

Using the credentials obtained from the FTP service, successful SSH authentication was achieved as the user 'alice' with the password 'nicole'. Upon login, an interactive shell was established, confirming remote user-level access to the system.

Post-authentication validation was performed using standard identity and environment checks (e.g., user identity, hostname, and network configuration) to confirm access context.

Despite internal audit documentation suggesting that Alice may have been granted temporary sudo access, system checks indicate that Alice no longer has access to sudo privileges. Post-authentication enumeration

```

(kali@kali) ~/Project1
$ ssh alice@192.168.56.21
alice@192.168.56.21's password:
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.8.0-94-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Mon Feb  2 05:03:03 PM UTC 2026

System load: 0.16           Memory usage: 5%    Processes:   120
Usage of /:  28.0% of 9.75GB Swap usage:  0%    Users logged in: 0

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Mon Feb  2 16:59:35 2026 from 192.168.56.5

```

Figure 3: SSH Command with Alice's Credentials

```

alice@project1:~$ whoami
alice
alice@project1:~$ id
uid=1001(alice) gid=100(users) groups=100(users)
alice@project1:~$ hostname
project1
alice@project1:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp-static: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:34:8b:2f brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.21/24 brd 192.168.56.255 scope global enp-static
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe34:8b2f/64 scope link
        valid_lft forever preferred_lft forever
alice@project1:~$ sudo -l
[sudo] password for alice:
Sorry, user alice may not run sudo on project1.

```

Figure 4: Commands for Validation Check

```

alice@project1:~$ ls -la /home
total 32
drwxr-xr-x  8 root    root    4096 Jan 30 13:56 .
drwxr-xr-x 23 root    root    4096 Jan 30 04:08 ..
drwxr-x---  7 alice   users  4096 Jan 30 19:14 alice
drwxr-x---  9 bob     users  4096 Jan 30 19:03 bob
drwxr-x---  6 eve     users  4096 Jan 30 14:18 eve
drwxr-xr-x  7 ftpuser users  4096 Jan 30 19:13 ftpuser
drwxr-x---  8 mallory users  4096 Jan 30 17:31 mallory
drwxr-x---  4 project1 project1 4096 Feb  1 23:22 project1

```

Figure 5: List of Home Directories

```

(kali@kali)-[~/Project1]
$ ssh bob@192.168.56.21
bob@192.168.56.21's password:
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.8.0-94-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Mon Feb  2 05:58:36 PM UTC 2026

System load: 0.0          Memory usage: 6%    Processes:      124
Usage of /:  28.1% of 9.75GB Swap usage:   0%    Users logged in: 0

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

```

Figure 6: SSH Command with Bob's Credentials

of Alice's home directory revealed files and directories consistent with those previously accessible via the FTP service. No additional sensitive data was identified within the SSH session that had not already been exposed through FTP.

Multiple local user accounts were identified on the system, with home directories restricted to their respective owners. Although several users share a common group, directory permissions prevented cross-user access.

### 5.3.4 Additional User Access Attempts (Bob)

Using credentials obtained during the web server reconnaissance phase, SSH authentication as the user bob was attempted. Authentication was successful using the reused password identified in the exposed users.bak file. Upon login, we verified the execution context using whoami, confirming access as the non-privileged user bob.

Post-authentication enumeration showed that Bob does not have sudo privileges. Running `sudo -l` prompted for a password and returned a denial message, indicating that Bob is not authorized to execute commands with elevated permissions. This confirms that, while credential reuse allowed successful SSH access, the account is constrained by least-privilege controls and does not provide a direct privilege escalation path.

Further inspection of Bob's home directory revealed contents consistent with those previously accessible via the FTP service, indicating that SSH access did not expose additional sensitive data beyond what was already disclosed through service misconfiguration.

```

bob@project1:~$ whoami
bob
bob@project1:~$ id
uid=1002(bob) gid=100(users) groups=100(users)
bob@project1:~$ hostname
Command 'hostname' not found, did you mean:
  command 'hostname' from deb hostname (3.23+nmulubuntu1)
Try: apt install <deb name>
bob@project1:~$ hostname
project1
bob@project1:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp-static: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:34:8b:2f brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.21/24 brd 192.168.56.255 scope global enp-static
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe34:8b2f/64 scope link
        valid_lft forever preferred_lft forever
bob@project1:~$ sudo -l
[sudo] password for bob:
Sorry, user bob may not run sudo on project1.

```

Figure 7: Commands for Validation Check

## 5.4 Apache Web Server

### 5.4.1 Directory Brute-Force with Dirb

We know from the port scanning that there is an http port open. To check it out we run "dirb http://192.168.56.21". This will scan the website for different pages that are not listed on the homepage. The scan shows that there are many directories that are not shown on the homepage. The following directories have been discovered /backup, /internal, /login, /robots.txt, /notes, /uploads, /index.html.

```

--- Scanning URL: http://192.168.56.21/ ---
=> DIRECTORY: http://192.168.56.21/backup/
+ http://192.168.56.21/index.html (CODE:200|SIZE:219)
=> DIRECTORY: http://192.168.56.21/internal/
=> DIRECTORY: http://192.168.56.21/login/
=> DIRECTORY: http://192.168.56.21/notes/
+ http://192.168.56.21/robots.txt (CODE:200|SIZE:54)
+ http://192.168.56.21/server-status (CODE:403|SIZE:278)
=> DIRECTORY: http://192.168.56.21/uploads/
--- Entering directory: http://192.168.56.21/backup/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)
--- Entering directory: http://192.168.56.21/internal/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)
--- Entering directory: http://192.168.56.21/login/ ---
+ http://192.168.56.21/login/index.html (CODE:200|SIZE:733)
--- Entering directory: http://192.168.56.21/notes/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)
--- Entering directory: http://192.168.56.21/uploads/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

```

Figure 8: Output of dirb command

#### Listing 4: DIRB Scan: Listable Directory Discovery

```
Script started on 2026-02-01 10:03:53-06:00 [TERM="xterm-256color" TTY="/dev/pts/1" COLUMNS="77" LINES="28"]

]0;student@kali: ~
[0m[27m[24m[J[32m*-- ([1m[32m[34mstudent@kali[0m[34m[32m) - [[1m[32m[39m~[0m[32m)
•[1m[32m[34m$[0m[34m[39m [K[?1h=[?2004hd[4md[24m[4md[24m[38;5;244mirb http://192.168.56.20/[39m[25D[4md[39m[4mi[24m[4md[4mi[39m[4mr[24m[24m[36md[24
m[36mi[24m[36mr[39m[36mr[36mb[39m[36mb[36m [39m[36mb[39m[39m [39mh[39mt[39mt[39mp[39m:[39m/[39m/[39m1[39m9[39m2[39m.[39m1[39m6[39m8[39m.[39m5
[39m6[39m.[39m2[39m1[39m /[?11>[?20041

-----
DIRB v2.22
By The Dark Raver
-----

START_TIME: Sun Feb 1 10:04:44 2026
URL_BASE: http://192.168.56.21/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----

*** Generating Wordlist...

GENERATED WORDS: 4612

---- Scanning URL: http://192.168.56.21/ ----
*** Calculating NOT_FOUND code...

--> Testing: http://192.168.56.21/.bash_history
--> Testing: http://192.168.56.21/.bashrc
--> Testing: http://192.168.56.21/.cache
--> Testing: http://192.168.56.21/.config
--> Testing: http://192.168.56.21/.cvs
--> Testing: http://192.168.56.21/.cvsignore
--> Testing: http://192.168.56.21/.forward
--> Testing: http://192.168.56.21/.git/HEAD
--> Testing: http://192.168.56.21/.history
```

#### 5.4.2 Sensitive Data Exposure

By looking at robots.txt, which has code 200, it shows 2 directories that they want to be hidden /backup and /internal.

```
(student@kali)-[~]
$ curl -i http://192.168.56.21/robots.txt
HTTP/1.1 200 OK
Date: Sun, 01 Feb 2026 18:49:07 GMT
Server: Apache/2.4.58 (Ubuntu)
Last-Modified: Fri, 30 Jan 2026 20:48:43 GMT
ETag: "36-649a119507ee0"
Accept-Ranges: bytes
Content-Length: 54
Content-Type: text/plain

User-agent: *
Disallow: /backup/
Disallow: /internal/
```

Figure 9: Directory robots.txt

By taking a look at the /backup directory we will find what was trying to be hidden. There is a file called users.bak which can be found. This file contains information about user login information that is crucial to accessing the system. This is where we discover the password to Bob's account is charlie. Bob's login can now be used in the other services to discover more about the system.

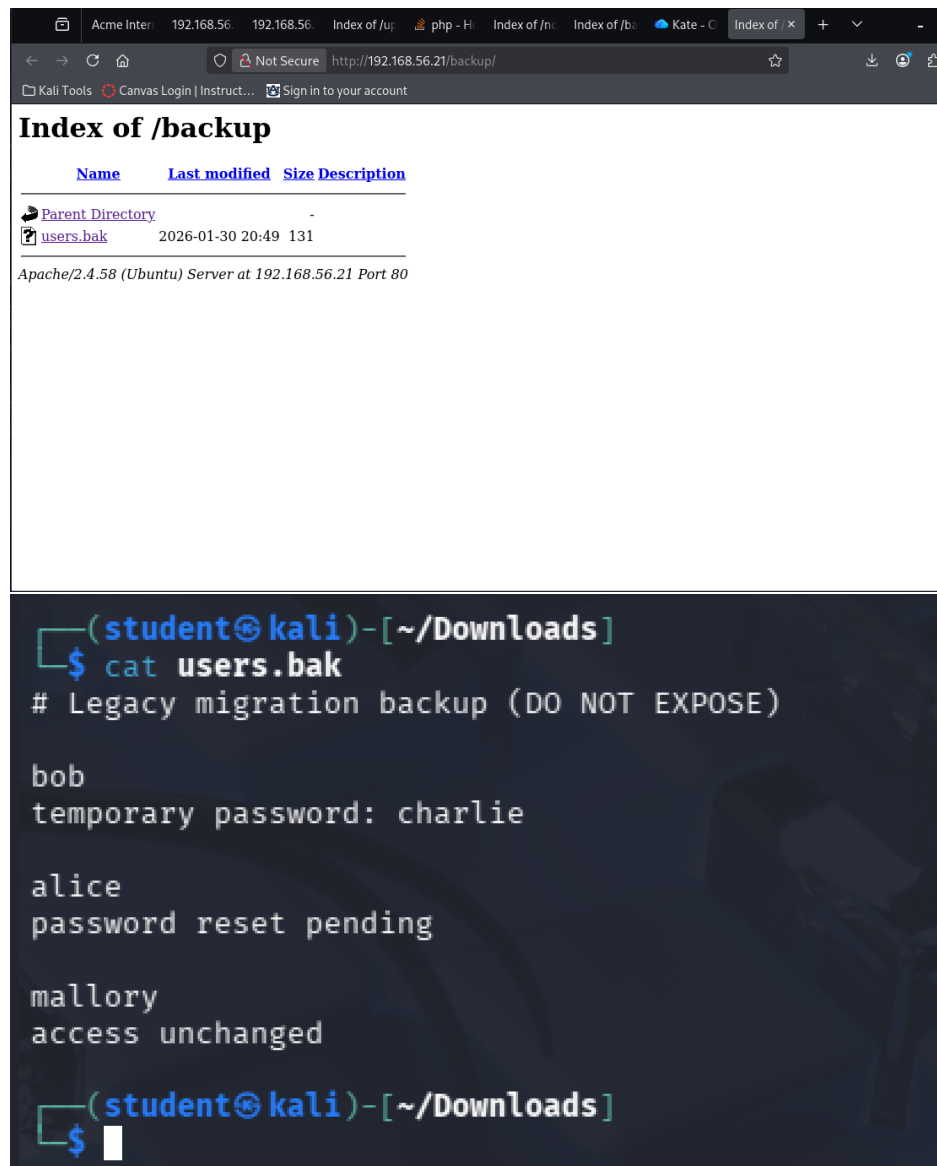


Figure 10: Contents of /backup directory and users.bak

The next hidden directory mentioned in robots.txt was /internal. There is a file called staff.txt. This contains more information about user login information. It backups our earlier claim that Bob's password is charlie since that is a child's name. It also tells us that Bob uses the same password for everything so charlie should work for all the ports. It also tells us that Mallory handles sys admin and can give out sudo access. This tells us that the web login is not working right now so everything uses SSH.

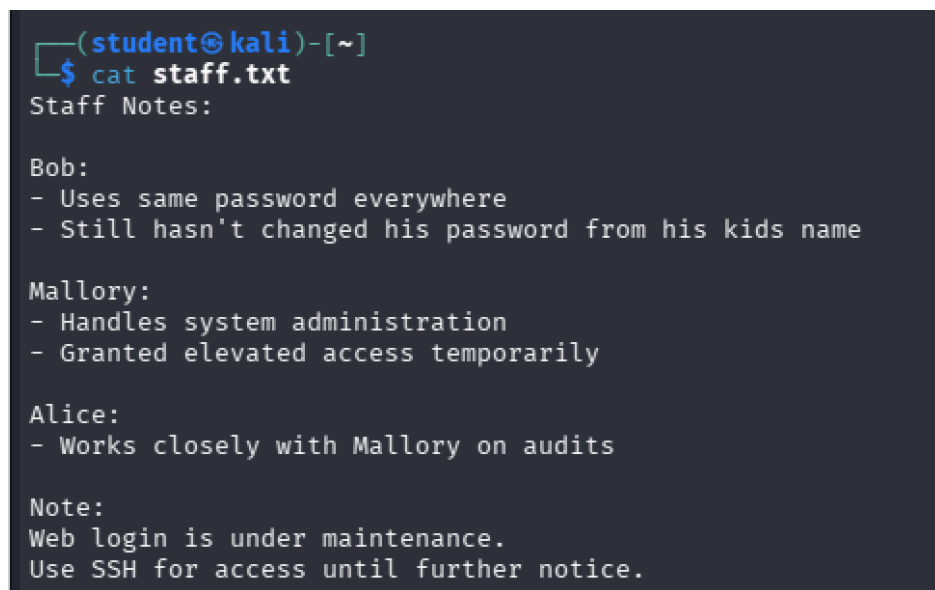
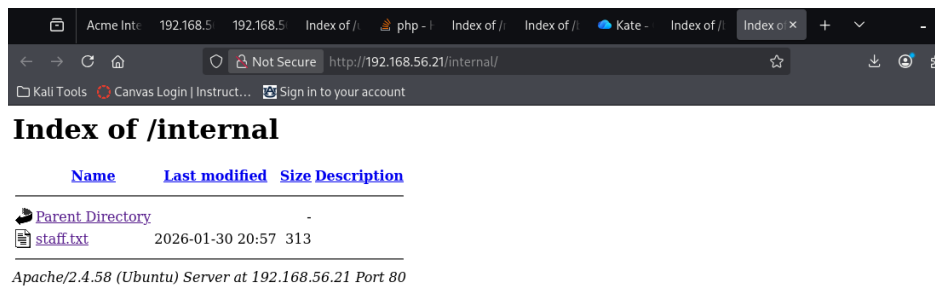


Figure 11: Contents of /internal directory and staff.txt

The rest of the directories do not have information on them. The login page leads to login.php which is blank because as we found out in staff.txt the web login is not functioning.

#### Listing 5: Key discoveries from HTTP services

```
[0m[27m[24m[J[32m•--([1m[32m[34mstudent@kali[0m[34m[32m)-[1m[32m[39m~[0m[32m]
•-[1m[32m[34m$[0m[34m[39m [K[?1h=[?2004hc[4mc[24m[4mc[24m[38;5;244mlear[39m[4mc[39m[4mu[24m[39m [39m [39m [38;5;244mrl -i http://192.168.56.21/internal[39m[35D[4mc[4mu[39m[4mr
  ↳ [24m[4mr[39m[4ml[24m[24m[36mc[24m[36mc[24m[36mr[24m[36ml[39m[36ml[36m [39m[36ml[39m[39m [39m-[39mi[39m [39mh[39mt[39mt[39mp[39m:[39m/[39m/[39m1[39m9[39m2[39m.[39m1
  ↳ [39m6[39m6[39m.[39m5[39m6[39m.[39m2[39m1[39m/[39m1[39mn[39mt[39me[39mr[39mn[39ma[39ml[32D[32m-[32mi[39m[30C [38;5;244ml[39m [39m [38;5;244mal[39m [39m [39m [38;5;244
  ↳ mnal[39m [39m [39m [39m [38;5;244mrnal[39m [39m [39m [39m [39m [38;5;244mernal[39m [39m [39m [39m [39m [39m [38;5;244mternal[39m [39m [39m [39m [39m [39m
  ↳ [38;5;244mternal[39m [39m [39m [39m [39m [39m [8D[38;5;244minternal[39m[8D[39mr[39m [39m [39m [39m [39m [39m [38;5;244mobots.txt[39m[9D[39mo[39mb[39
  ↳ mo[39mt[39ms[39m.[39mt[39mx[39mt[?11>[?2004l

HTTP/1.1 200 OK

[1mDate[0m: Sun, 01 Feb 2026 17:09:33 GMT

[1mContent-Length[0m: 54

[1mContent-Type[0m: text/plain

HTTP/1.1 200 OK

[1mDate[0m: Sun, 01 Feb 2026 17:09:47 GMT

[1mServer[0m: Apache/2.4.58 (Ubuntu)
```

## 6 Observations and Recommendations

The following observations summarize the key conditions that enabled the compromise of the target system. While some of these issues may appear minor in isolation, their combined presence allowed for credential disclosure, cross-service authentication, and unauthorized system access. These findings highlight weaknesses in service configuration, credential management, and access control practices.

### 6.0.1 Observation 1: Insecure FTP Configuration and Anonymous Access

The FTP service was configured to allow anonymous authentication, providing unauthenticated users with directory listing access across multiple user home directories. This exposure enabled attackers to enumerate system users and access sensitive files stored within user directories. The presence of internal notes and audit files within these directories significantly increased the impact of this misconfiguration by directly exposing valid credentials.

**Recommendation:** Anonymous FTP access should be disabled unless explicitly required. File permissions should be reviewed to ensure that sensitive documentation, such as audit notes and credentials, is not accessible through externally facing services. FTP should be replaced with more secure file transfer mechanisms where possible. If FTP with anonymous authentication is required, sensitive documents and information should never be accessible.

### 6.0.2 Observation 2: Inadequate File System Permissions Management

One major issue identified both in ftp and ssh is incorrect file and directory permissions. The user "alice" was able to access files and directories belonging to other users while not having root access to the machine. This allows users and attackers to access potentially sensitive information belonging to other users.

**Recommendation:** Users should be the sole owners of their home directories and the file system should enforce that ownership. This would prevent non-root users from accessing the information belonging to other users. If a non-sensitive file or folder has to be accessed often by multiple users, it should be located in a shared directory. This allows distributed access where it is required without potentially exposing users' sensitive or private documents.

### 6.0.3 Observation 3: Inadequate Password Policies

Passwords are not required to be an adequate complexity, simple passwords are vulnerable to password cracking attempts. Passwords are not required to be reset after first login, "alice" had the same simple password given to her in onboarding. There is also some inadequate treatment of passwords and credentials by the corporation in the management plane.

#### Recommendations:

1. Implement Password Complexity Requirements, Enforce Complexity Requirements within the OS
2. Enforce Password Resets on New Users' First Logins
3. Introduce Company Policy regarding proper storage of passwords. Passwords should not be stored in files and there should be policies for "in-office" storage of passwords as well.

### 6.0.4 Observation 4: Exposure of Sensitive Backup and Internal Files via Web Server

The Apache web server exposed hidden directories through misconfigured access controls. Files such as `users.bak` and `staff.txt` contained sensitive credential information and internal operational notes. These files were accessible without authentication and directly contributed to successful credential reuse across multiple services.

**Recommendation:** Backup files and internal documentation should never be stored in web-accessible directories. Web server configurations should restrict directory listing and enforce proper access controls. Regular audits should be conducted to identify and remove sensitive files from production web environments.

#### 6.0.5 Observation 5: Credential Reuse Across Services

Credentials obtained from FTP and HTTP enumeration were successfully reused to authenticate to the SSH service. This demonstrated a lack of credential separation between services and increased the overall impact of a single credential disclosure. The reuse of simple, predictable passwords further reduced the effort required to gain unauthorized access.

**Recommendation:** Unique credentials should be enforced across services, and password complexity requirements should be strengthened. Implementing centralized authentication mechanisms and enforcing password rotation policies would significantly reduce the effectiveness of credential reuse attacks.

#### 6.0.6 Observation 6: Improper Management of Temporary Privileged Access

The internal audit documentation indicated that temporary elevated access had been granted to a user account during a previous review process. Although elevated privileges were no longer present at the time of SSH access, the existence of such documentation highlights weak privilege lifecycle management and an increased risk of privilege escalation.

**Recommendation:** Temporary privileged access should be strictly time-bound and automatically revoked after use. Documentation containing privilege information should be secured, and periodic reviews should be conducted to verify that no unnecessary elevated permissions remain assigned.

## 7 Conclusion

This vulnerability assessment evaluated the security posture of the target system by simulating a realistic external attack scenario. Throughout the engagement, multiple exploitable weaknesses were identified and leveraged to demonstrate how an attacker could gain unauthorized access using commonly available tools and techniques. The actions performed during this assessment required minimal technical sophistication and relied primarily on configuration weaknesses and improper information handling.

The compromise path demonstrated in this report involved the chaining of multiple issues across exposed services. Initial access was achieved through insecure FTP configuration, which enabled the disclosure of sensitive user information. Additional credential data was obtained through misconfigured web server directories, further increasing the attacker's ability to pivot across services. These credentials were subsequently reused to authenticate to the SSH service, resulting in remote user-level access to the system.

The findings from this assessment indicate that an external attacker could successfully compromise the target system without the use of advanced exploits or specialized attack tools. The vulnerabilities identified emphasize the importance of enforcing proper access controls, securing internal documentation, and implementing strong credential management practices. Addressing these weaknesses would significantly reduce the likelihood of similar attack scenarios and improve the overall security posture of the system.